

Metadatengestützte Zugriffskontrolle in On-Premise Data Lakes

Masterarbeit Informatik (IT-Sicherheit)

Motivation

Data Lake

Motivation

Problemstellung

Motivation

Inwiefern ermöglicht die Ableitung sicherheits- und governance-relevanter Attribute aus bestehenden Metadaten eines On-Premise Data Lakes eine wirksame und feingranulare Zugriffskontrolle auf Query-Engine-Ebene?

1. Ableitung

Welche sicherheits- und governance-relevanten Attribute lassen sich aus vorhandenen Metadaten ableiten?

2. Durchsetzbarkeit

Wie lässt sich metadatengestützte ABAC auf Query-Engine-Ebene technisch umsetzen?

3. Grenzen

Welche Trade-offs und Limitationen ergeben sich im laufenden Betrieb?

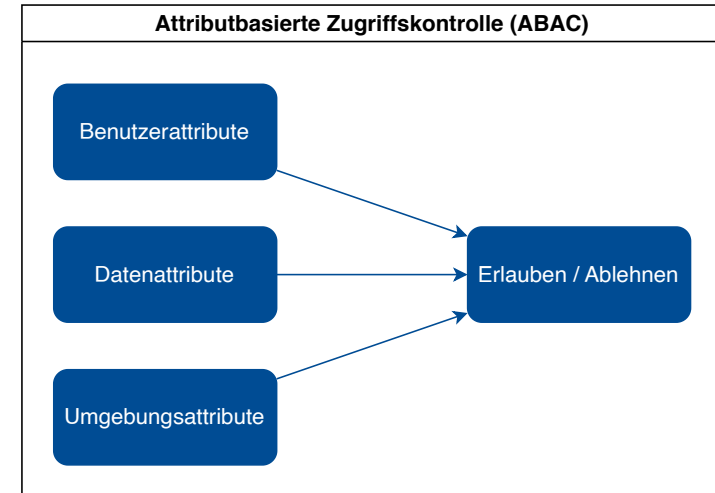
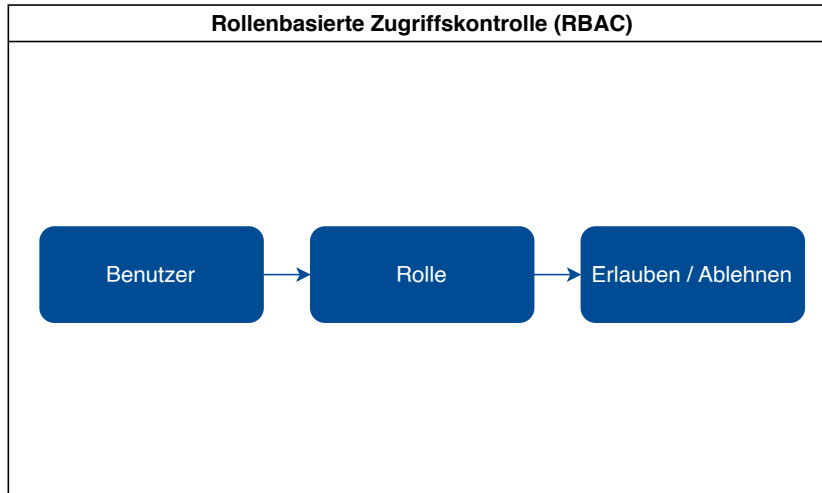
Agenda

1. Motivation
2. Konzept
3. Evaluation
4. Fazit

Konzept

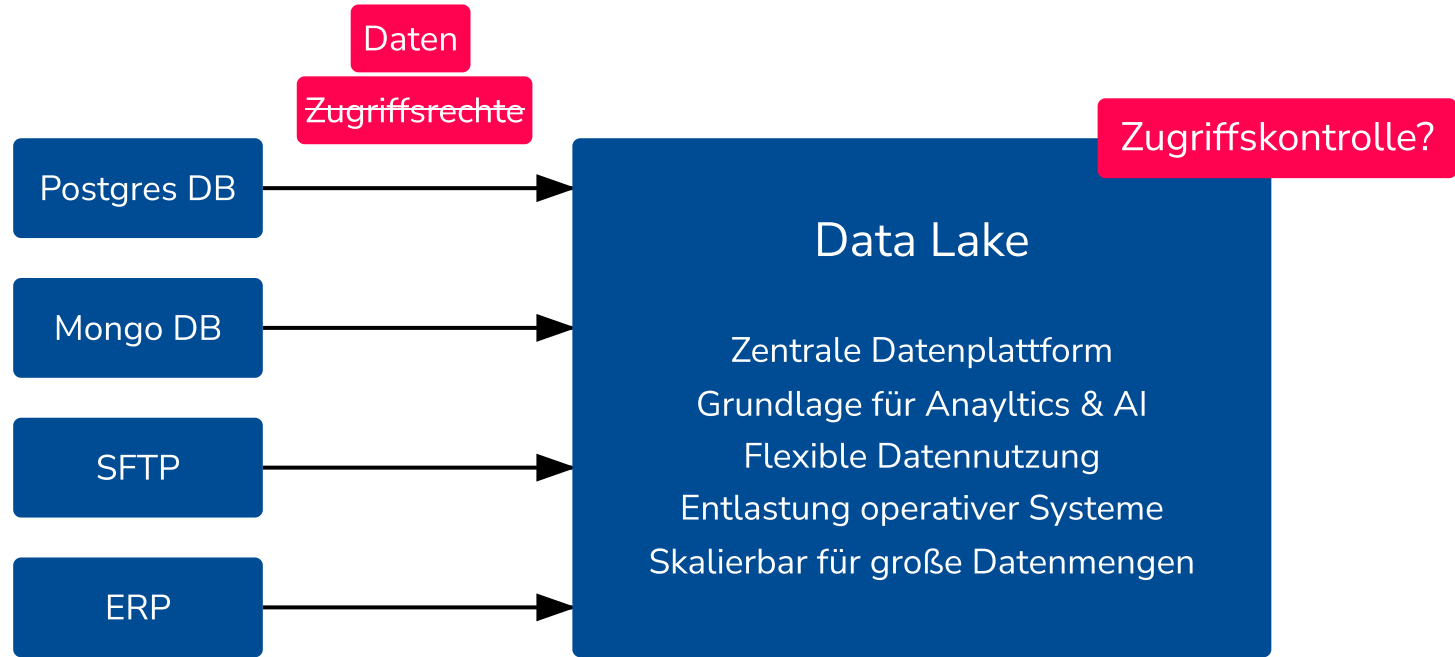
Lösungsansätze

Konzept



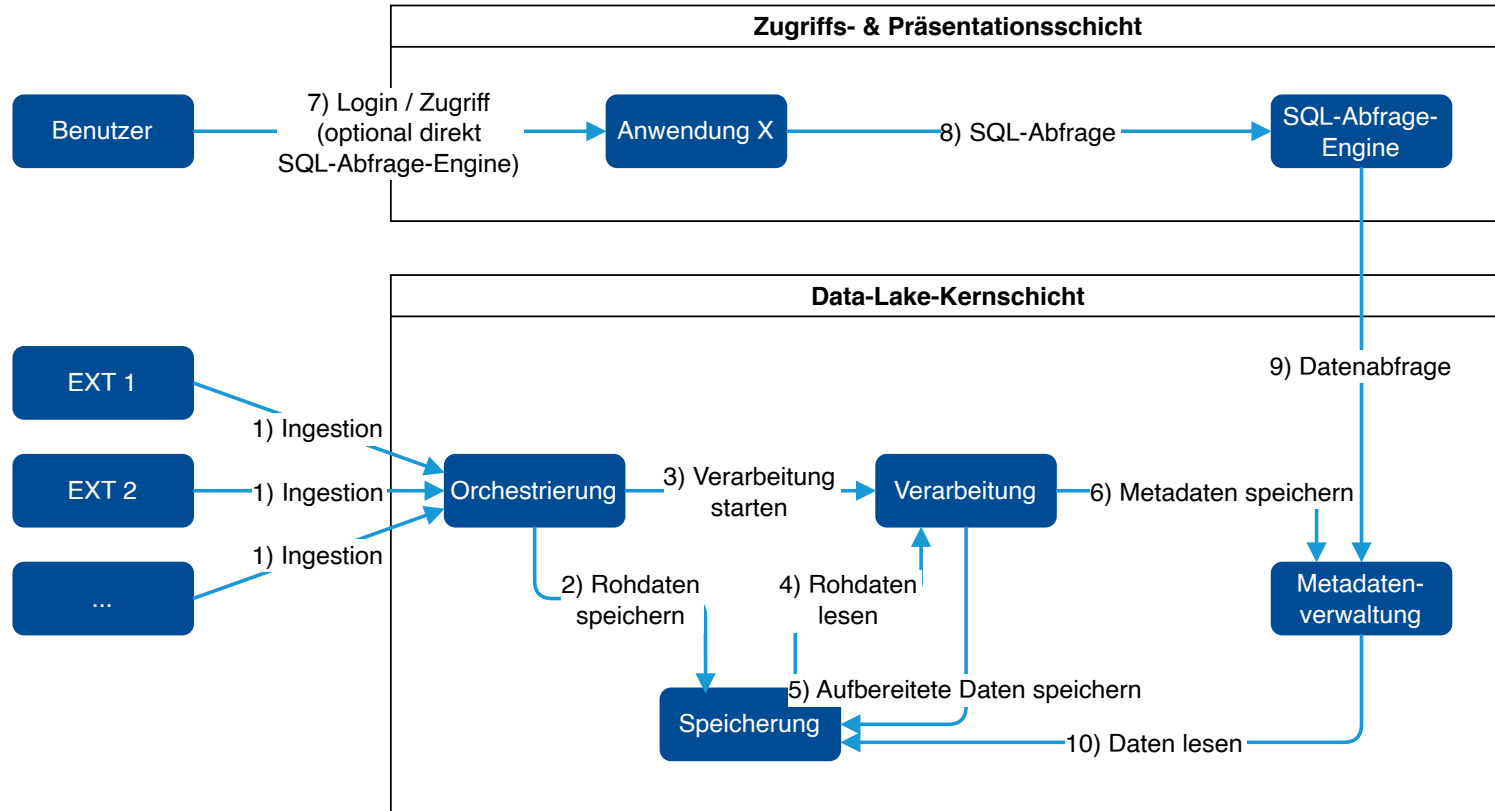
Architekturidee

Konzept



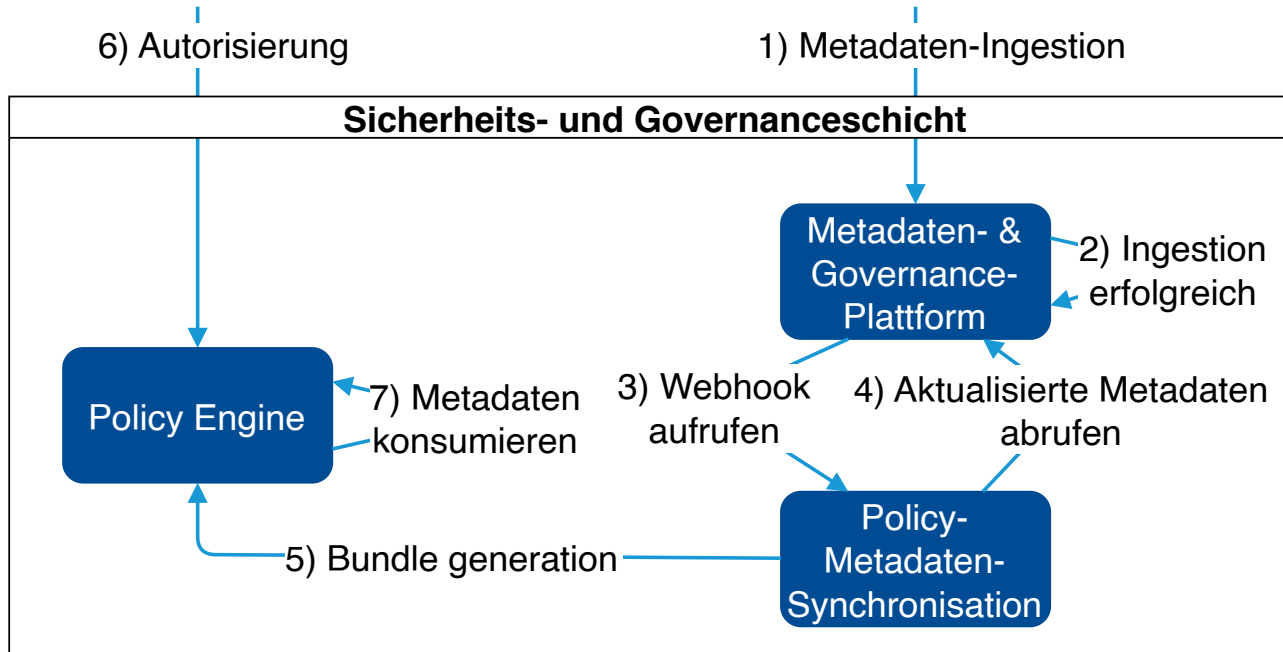
Ausgangsarchitektur

Konzept



Metadatenableitung

Konzept



Evaluation

Bewertungsrahmen

Evaluation



Bewertungsskala

Evaluation

niedrig	Das Kriterium wird für den untersuchten Zugriffspfad nicht hinreichend erfüllt.
mittel	Das Kriterium wird für den untersuchten Zugriffspfad grundsätzlich erfüllt.
hoch	Das Kriterium wird für den untersuchten Zugriffspfad weitgehend erfüllt.

I. Administration

mittel bis hoch

Evaluation

Stärken	Einschränkungen
Gute Integration in Open Policy Agent und LDAP	Eingeschränkte Transparenz über effektive Berechtigungen
Reduzierter manueller Verwaltungsaufwand durch Metadaten	Kein zentrales Audit-System
Versionierte Policy-Verwaltung via Git-Workflow	Fehlende Policy-Test- und Rollback-Funktionalität
Systemübergreifende Nutzbarkeit	

II. Enforcement

mittel bis hoch

Evaluation

Stärken

Ausdrucksstarke Rego-Policies

Feingranulare Zugriffskontrolle

Least-Privilege-Prinzipien

Fail-closed Verhalten

Trennung von Metadaten und Entscheidungslogik

Einschränkungen

Begrenzte Bypass-Kontrolle außerhalb des Zielsystems

Kein systematisches Policy-Konfliktmanagement

Fehlende Analyse minimaler Rechte

III. Performance

hoch

Evaluation

Stärken

Geringer Laufzeit-Overhead

Stabile Integration mit LDAP/Attributquellen

Zuverlässige Bundle-Verteilung

Gute Skalierbarkeit im betrachteten Use Case

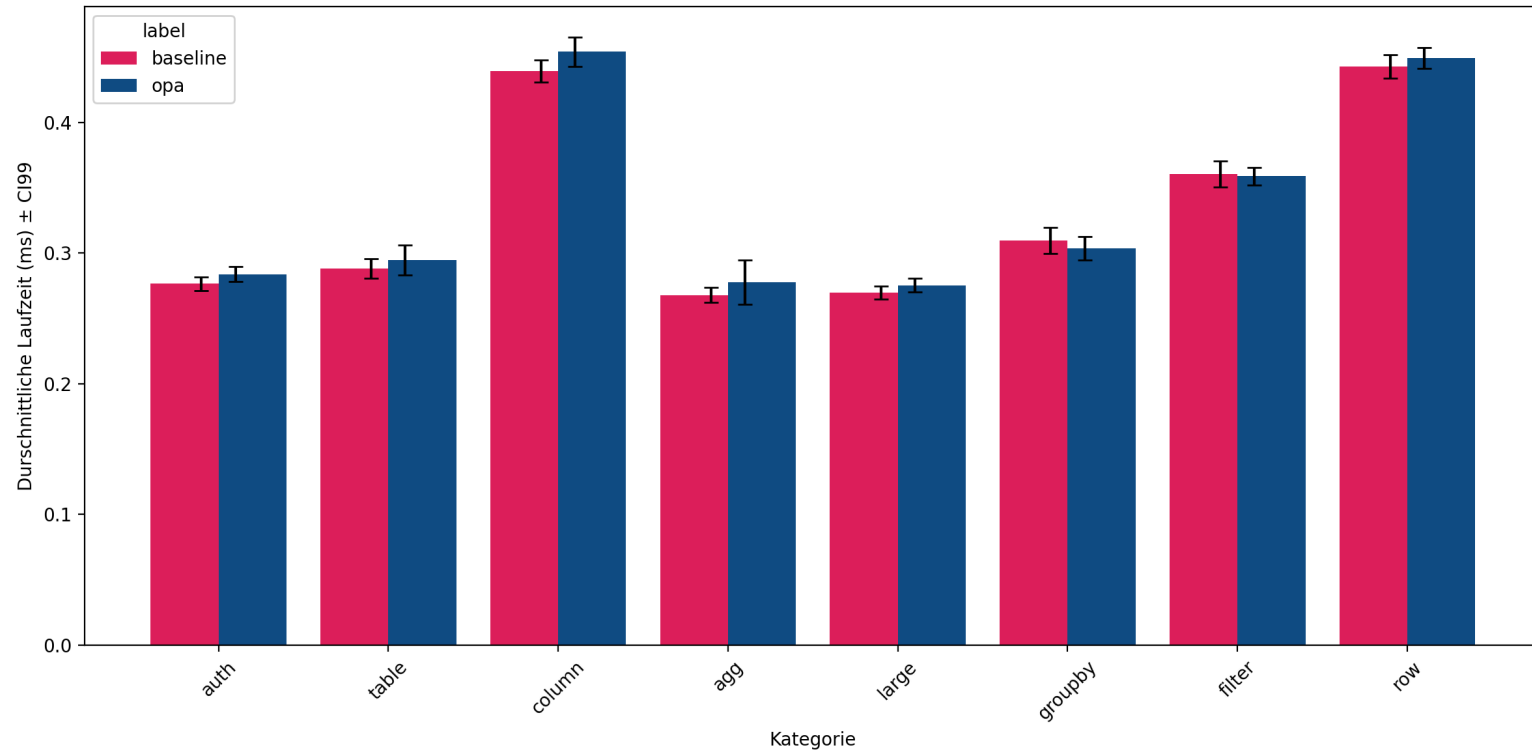
Effiziente Automatisierung gegenüber manueller Pflege

Einschränkungen

Eignung für Echtzeit-Szenarien

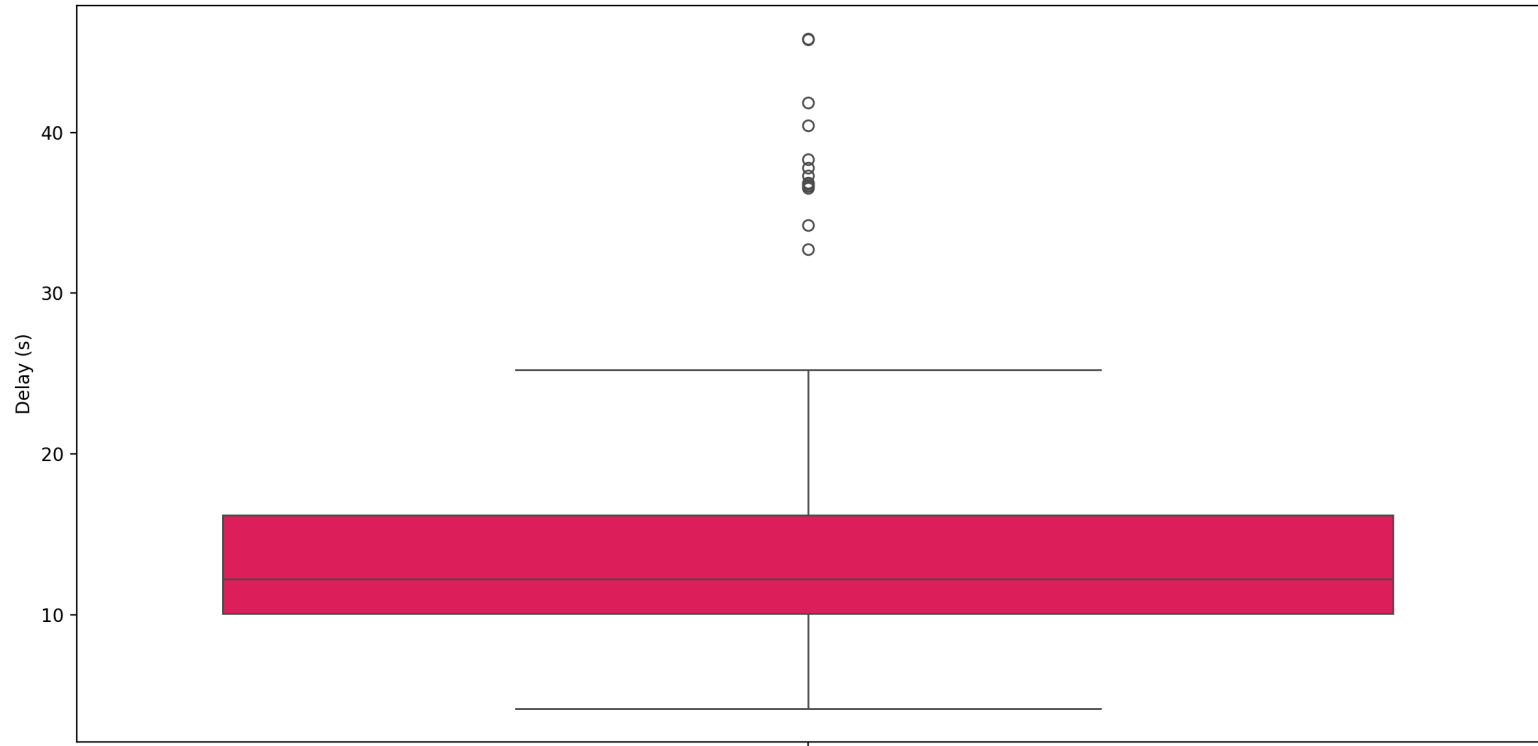
III. Performance: Overhead

Evaluation



III. Performance: Propagation-Delay

Evaluation



IV. Support

mittel

Evaluation

Stärken

Vorhandene APIs und Integrationsschnittstellen

Gute technische Erweiterbarkeit

Unterstützt systematische Integration

Einschränkungen

Keine integrierte Administrationsoberfläche

Kein zentrales Decision Logging

Keine formale Verifikation von Policies

Fehlende Compliance- und Audit-Nachweise

Fazit

Forschungsfrage

Fazit

Inwiefern ermöglicht die Ableitung sicherheits- und governance-relevanter Attribute aus bestehenden Metadaten eines On-Premise Data Lakes eine wirksame und feingranulare Zugriffskontrolle auf Query-Engine-Ebene?

1. Ableitung

Technische, fachliche und organisatorische Metadaten liefern geeignete ABAC-Attribute wie Sensitivität, Domäne, Verarbeitungsstufe und Herkunft.

2. Durchsetzbarkeit

Der Prototyp zeigt, dass sich Tabellen-, Spalten- und Row-Level-Kontrolle über Trino/OPA umsetzen lässt. Der gemessene Overhead liegt bei rund 1,6 %.

3. Grenzen

Metadatenqualität, Bundle-Synchronisation und fehlende UI/Audit-Funktionen sind zentrale Ausbaubedarfe für den produktiven Einsatz.

Ausblick

Fazit

- Auditierbarkeit, Decision Logs und Policy-Tests sollten ergänzt werden.
- Eine Übersicht effektiver Berechtigungen und automatisierte Metadatenvalidierung sind wichtige nächste Schritte.
- Weiterführende Forschung sollte Synchronisationsstrategien, automatisierte Klassifikation und Compliance-Integration untersuchen.

Fragen?